UNIVERSITY OF EDINBURGH

COLLEGE OF SCIENCE AND ENGINEERING

SCHOOL OF INFORMATICS

INFR11158 USABLE SECURITY AND PRIVACY PG AND INFR11230 UG

Saturday 4th May 2024

13:00 to 15:00

INSTRUCTIONS TO CANDIDATES

Answer QUESTION 1 and ONE other question.

Question 1 is COMPULSORY. If both QUESTION 2 and QUESTION 3 are answered, only QUESTION 2 will be marked.

All questions carry equal weight.

This is a NOTES PERMITTED, CALCULATORS NOT PERMITTED examination. Candidates may consult up to THREE A4 pages (6 sides) of notes. CALCULATORS MAY NOT BE USED IN THIS EXAMINATION.

MSc Courses

Convener: A.Pieris
External Examiners: A.Cali, V.Gutierrez Basulto

THIS EXAMINATION WILL BE MARKED ANONYMOUSLY

1. THIS QUESTION IS COMPULSORY

(a) Usable security and privacy research presents multiple challenges, such as its interdisciplinarity (as discussed in lectures). Name four other reasons and briefly explain each of them. [*4 marks*]

(b) Phishing is one major security threat Internet users face, e.g., when browsing. List three common approaches to protect users from phishing and briefly explain each of them. [*3 marks*]

(c) When analyzing user study results, we frequently encounter unstructured data, such as text transcripts, images, and videos. Name and briefly explain the two main approaches for coding data and the two aspects for measuring the reliability of the coding process. [*4 marks*]

(d) More than concepts of authentication and authorization, we discussed the three other principles of security under the *CIA* definition. Name each principle and explain each of them using real-world examples. [*6 marks*]

(e) Social media provides researchers with extensive data to understand users' perspectives and discussion on security and privacy without requiring direct interaction with them in a laboratory setting. However, we still need to collect and analyze this data in an ethical manner. Name and briefly explain four practices for researching social media data ethically. [*4 marks*]

(f) Explain two aspects using the *NEAT* framework that make a good payment security warning (e.g., warning for suspicious payment) sent by a mobile banking service. [*4 marks*]

2. ANSWER EITHER THIS QUESTION OR QUESTION 3

You are developing a virtual reality game, and you are responsible for designing a user authentication system for its in-game purchases, in addition to the standard password authentication as part of the multi-factor authentication. You have access to all the input and output modalities provided by the virtual reality headset (possible modalities include but not limit to those shown in Figure 1). Answer the following questions in constructing studies to design and analyze this authentication system.

(a) Propose an authentication method different from password and explain how this authentication method works (including what are the unique features associated with your identity). Then, name the three major types of authentication factor discussed in the lecture and describe how passwords and your proposed authentication fit into each authentication factor (hint: password belongs to the authentication factor of "something you _____"). [*6 marks*]

(b) Given the method proposed above, now you are designing and evaluating your prototype for multi-factor authentication in virtual reality. There are several design choices you can potentially consider in the authentication prototype, e.g., the interface design and form of interaction. Define a research question to evaluate one usability aspect for the authentication prototype in a lab study. What are the dependent and independent variables in your study? Define one metric to measure "usability". Explain your response. [*5 marks*]

(c) Design a lab study to study the above question. Describe and justify your study method used, setup (e.g., resources needed and recruitment), and tasks involved in conducting the study. [*8 marks*]

(d) Given the proposed authentication system, identify and explain a limitation or tradeoff. You can do this by comparing it to other alternatives of authentication. [*2 marks*]

(e) When using the proposed system for authentication in virtual reality, how could the security of it be compromised by other potential adversaries? And what could motivate the attacker? Explain and justify your response. [*4 marks*]

QUESTION CONTINUES ON NEXT PAGE

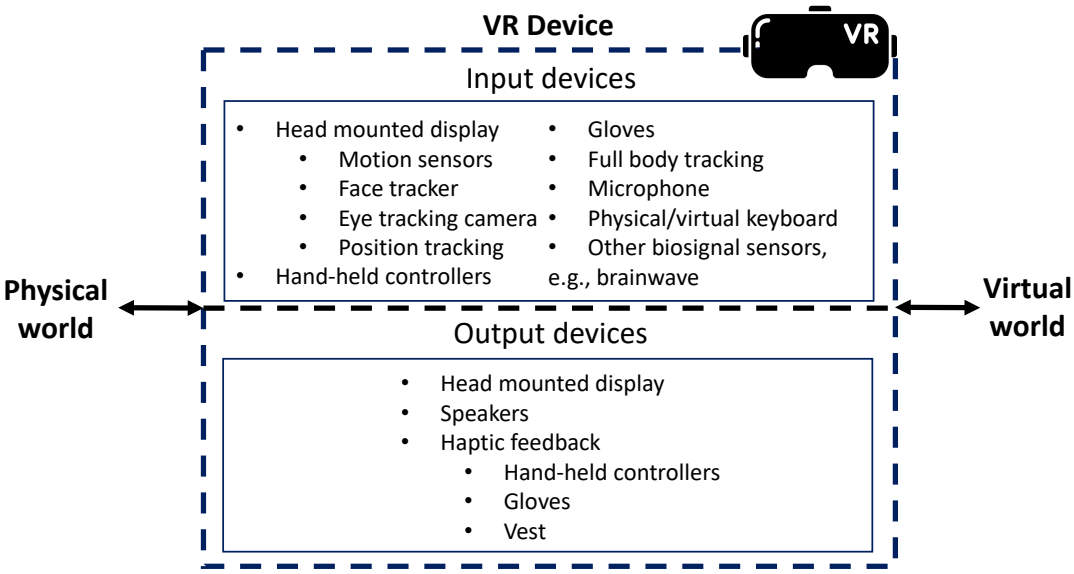

Figure 1: An example of the input and output modalities of a VR headset.

3. ANSWER EITHER THIS QUESTION OR QUESTION 2

Alex and Bob are looking for a smart camera equipped with an app. The product should allow real-time monitoring of their home remotely and give the option to review footage later. Their main goal is to monitor their new-born baby, as their work schedules prevent them from being at home all the time. They also have another child, Eve, who is a teenager. Eve sometimes comes home earlier after school while Alex and Bob are away.

(a) Identify and explain three potential privacy concerns this family may have because of installing and using the smart camera. [*6 marks*]

(b) To address any one of the privacy concerns identified above, apply the *Contextual Integrity* framework to propose a privacy control rule in the data flow of the usage of a smart camera. Then, specify the five variables in the framework and explain in the context of the family. [*6 marks*]

(c) The online shopping website attaches a security and privacy "nutrition label" alongside each product page (one illustrative figure is shown in Figure 2). The nutrition label contains security and privacy practices of the camera, e.g., what data are collected and how. The label was filled out by the device manufacturer and audited by the online selling company. Apply the concepts of the *Human in the Loop Framework* to identify and explain three potential reasons that such communication using the security and privacy nutrition label here may fail and potential solutions correspondingly. [*9 marks*]

(d) Alex and Bob found out that the privacy practices on the label are not very accurate, compared to what they observed during usage. Name and explain a reason why this discrepancy could happen. [*2 marks*]

(e) One day, Alex noticed that their camera appeared to have an Artificial Intelligence (AI) analytics feature enabled automatically after a software update, despite no one in their family activating this feature. What is the most likely privacy right being violated by the software developer? How could the company potentially misuse such a feature? Explain your response. [*2 marks*]

QUESTION CONTINUES ON NEXT PAGE

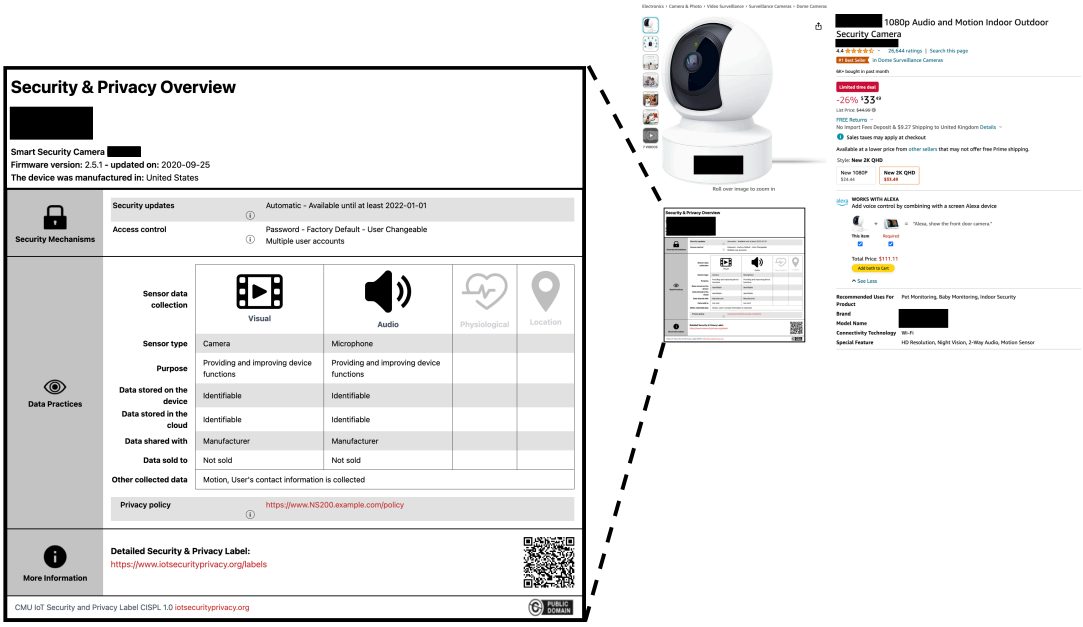

Figure 2: An example of the security and privacy nutrition label for the smart camera showing on the online shopping website (label zoomed in for better illustration).